



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Claroty finds authentication bypass, RCE flaws in Vertiv UPS management cards that could disrupt data center operations

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-16
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | Claroty finds authentication bypass, RCE flaws in Vertiv UPS management cards that could disrupt data center operations - Vulnerability Report

Published: 2026-06-16 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

1. Executive Summary

Claroty Team82 disclosed two critical vulnerabilities in Vertiv Liebert UPS communication cards used to remotely manage uninterruptible power supply (UPS) systems in data centers and critical infrastructure environments. The affected product families are Vertiv Liebert RDU101 and Liebert IS-UNITY / IS-UNITY-DP network cards. Both issues received CVSS v3.1 base scores of 9.8 and can be exploited over the network without authentication when vulnerable management services are reachable.

The primary operational risk is not limited to compromise of a small embedded management card. These cards sit in the power-management path for servers, routers, firewalls, building systems, and virtualization platforms that depend on UPS devices for continuity and controlled shutdown. Exploitation could allow an attacker to bypass the web interface login, change configuration, upload firmware, disrupt UPS management, or execute arbitrary code on the card. In a poorly segmented environment, that access can become a route to data-center disruption during a power event or a coercive leverage point during ransomware/extortion activity.

Vertiv has released updated firmware and recommends upgrading Liebert RDU101 to version `1.9.1.2\_0000001` or later and IS-UNITY to version `8.4.3.1\_00160` or later. Lost Boys Cyber assesses this as a high-priority remediation item for operators with Vertiv UPS management cards exposed to corporate IT, vendor remote access, data-center operations networks, or the internet. Public reporting does not indicate active exploitation as of this review, but the attack surface, low exploit complexity, and operational importance of UPS systems justify accelerated patching, exposure reduction, and focused telemetry review.

Field	Assessment
Report ID	LBC-VTI-2026-080
Report Type	Vulnerability Report
Classification	TLP:CLEAR
Subject	Vertiv Liebert RDU101 and IS-UNITY / IS-UNITY-DP UPS network card vulnerabilities
Published Source Date	2026-06-11 Industrial Cyber; 2026-06-09 Claroty Team82 research
Lost Boys Cyber Review Date	2026-06-16 UTC
Overall Severity	Critical for reachable or poorly segmented UPS management interfaces
Exploitation Status	No confirmed in-the-wild exploitation identified in reviewed public sources
Priority Actions	Patch firmware, remove internet exposure, restrict management access, hunt for suspicious UPS-management activity

2. Intelligence Requirement

This report answers the following intelligence requirement for operators responsible for data-center, facilities, managed-service, and critical-infrastructure environments:

- What is the realistic risk from the newly disclosed Vertiv Liebert RDU101 and IS-UNITY UPS management card vulnerabilities?
- Which assets, versions, and services should be prioritized for exposure review and remediation?
- What detections and threat-hunting queries can security teams deploy while patching and segmentation work is underway?
- How should defenders interpret exploitation risk when public exploit details are limited but the affected devices protect high-value infrastructure?

Requirement	Analyst Response
Affected technology	Vertiv Liebert RDU101 and IS-UNITY / IS-UNITY-DP communication cards used for UPS management
Business impact	Potential disruption to power-management workflows, safe shutdown processes, data-center uptime, and infrastructure resilience
Adversary value	High for ransomware operators, initial-access brokers targeting facilities networks, and state-linked actors interested in operational disruption
Defensive objective	Prevent unauthenticated access to UPS management interfaces, detect scanning or suspicious web interactions, and validate firmware status

3. Source Review and Confidence

Lost Boys Cyber reviewed public reporting from Industrial Cyber, Claroty Team82's primary research publication, CISA's ICS advisory listing, and Vertiv security/update references surfaced through public search results. Claroty is the original researcher and coordinated disclosure source; Industrial Cyber is a secondary news source that accurately summarizes the Team82 findings and remediation guidance. CISA's advisory entry provides authoritative severity and CVSS vector context.

Source	Role	Key Evidence	Confidence
Claroty Team82, "Attacking UPS Network Cards to Take Down Data Centers"	Primary technical research	Identifies CVE-2025-46412 and CVE-2025-41426, affected product families, CVSS 9.8 ratings, firmware versions, and exploitation concepts	High
Industrial Cyber, 2026-06-11 article	Secondary reporting	Summarizes operational impact, Vertiv remediation guidance, and research methodology	High
CISA ICSA-25-140-10	Government ICS advisory	Confirms affected Vertiv Liebert RDU101 and UNITY issue, CVSS vector for CVE-2025-46412, and ICS advisory tracking	High
Vertiv support/security references	Vendor remediation source	Indicates firmware update availability for RDU101 and IS-UNITY product lines	Medium-High

Confidence is high that the vulnerabilities are real, remotely exploitable under exposed-service conditions, and patched by vendor firmware updates. Confidence is moderate regarding the exact prevalence of exposed vulnerable devices in any given customer environment because exposure depends on network architecture, remote-management practices, and asset inventory quality.

Assumptions used in this report:

- Affected cards may be reachable through HTTPS/HTTP management interfaces, SNMP, Modbus TCP, BACnet/IP, Telnet, or vendor remote operations paths depending on configuration.
- Detections below are intended to identify suspicious access patterns and exposure; they are not proof-of-exploit signatures because public reporting does not provide a stable exploit payload or endpoint list suitable for high-fidelity signatures.

- Organizations should validate firmware versions directly on the device or vendor management platform rather than relying only on vulnerability scanner banners.

4. Key Findings

Finding	Severity	Evidence	Defensive Implication
Vertiv Liebert RDU101 and IS-UNITY cards contain unauthenticated remotely exploitable flaws	Critical	CVE-2025-46412 and CVE-2025-41426 both reported with CVSS v3.1 9.8	Treat reachable management interfaces as emergency exposure until patched or isolated
CVE-2025-46412 enables authentication bypass through improperly protected webserver functions	Critical	Claroty describes URL/path confusion enabling unauthenticated access to sensitive web operations including configuration uploads and firmware upgrades	Restrict web management access, review logs for abnormal unauthenticated requests, and patch firmware
CVE-2025-41426 is a stack-based buffer overflow that can enable code execution	Critical	Claroty/CISA identify CWE-121 stack-based buffer overflow with potential code execution on device	Prioritize patching because device compromise can support persistence, disruption, or pivoting
UPS management-card compromise creates outsized operational risk	High	UPS cards can manage power continuity and safe shutdown behavior for servers, routers, firewalls, and virtualized workloads	Include facilities/OT power assets in cyber incident impact planning, not only IT servers
Public exploitation has not been confirmed, but exploitability is low-complexity when exposed	High	CVSS vector indicates network attack vector, low complexity, no privileges, no user interaction	Begin internet/VPN/vendor-access exposure review immediately; do not wait for exploit chatter

4.1 Vulnerability Metadata

CVE	CWE	Affected Product Families	CVSS v3.1	Impact
CVE-2025-46412	CWE-288: Authentication Bypass Using an Alternate Path or Channel	Vertiv Liebert RDU101; Liebert IS-UNITY / IS-UNITY-DP	9.8	Unauthenticated access to protected webserver functions; possible configuration/firmware manipulation
CVE-2025-41426	CWE-121: Stack-based Buffer Overflow	Vertiv Liebert RDU101; Liebert IS-UNITY / IS-UNITY-DP	9.8	Remote code execution on affected device under vulnerable conditions

4.2 Affected Products and Fixed Versions

Product / Family	Role	Architecture Notes from Claroty	Remediation Version
Vertiv Liebert RDU101	UPS communication / network management card	Linux ARM 32-bit	Update to `1.9.1.2_0000001` or later
Vertiv Liebert IS-UNITY / IS-	UPS communication / network	Linux PowerPC for IS-UNITY-	Update to `8.4.3.1_00160` or

UNITY-DP	management card	DP research validation target	later
----------	-----------------	-------------------------------	-------

4.3 Exposure Details

Exposure Surface	Why It Matters	Immediate Check
Web management interface	Claroty identified webserver authentication bypass logic affecting sensitive operations	Inventory HTTP/HTTPS listeners and restrict to a dedicated management subnet
Firmware/configuration upload paths	Authentication bypass reportedly affects configuration uploads and firmware upgrades	Review recent firmware/config-change history for unexpected changes
SNMP / Modbus / BACnet integration	UPS cards commonly integrate with monitoring and building-management systems	Confirm protocols are limited to required collectors and not routed broadly
Vendor remote access / VPN	Third-party access can bridge external users into management networks	Review vendor access groups, jump hosts, and MFA/session recording coverage
Virtualization shutdown integrations	Some UPS deployments integrate with platforms such as VMware vSphere for controlled shutdown	Validate that UPS-to-virtualization trust paths cannot be abused from general IT networks

5. Threat Context

UPS management cards occupy a sensitive boundary between cyber operations and physical availability. They often receive less security attention than firewalls, hypervisors, domain controllers, or internet-facing applications, but they can influence whether critical equipment remains powered and whether shutdown workflows behave safely. An attacker who compromises a UPS communication module may gain the ability to degrade monitoring, alter configuration, disrupt safe shutdown behavior, or create confusion during a power event.

The likely adversary interest falls into three categories:

- Ransomware and extortion operators may use UPS disruption as pressure against data centers, managed-service providers, hospitals, manufacturing sites, or logistics environments.
- State-linked or strategic disruption actors may target power-management dependencies to magnify the effect of other intrusions.
- Opportunistic scanners may add these CVEs to internet-exposure workflows once exploit details become public or are reconstructed from firmware diffing.

Scenario	Preconditions	Potential Effect	Analyst Confidence
External exploitation of exposed web interface	Vulnerable UPS card management interface reachable from internet, vendor network, or broad VPN segment	Unauthorized access, configuration changes, firmware manipulation, disruption	Medium-High
Internal pivot from IT network	Attacker has foothold on workstation/server subnet with route to facilities or data-center management VLAN	Control-plane access to UPS card and possible RCE	High where segmentation is weak
Coordinated disruption during power event	Attacker compromises card before outage or maintenance window	Failed alerting, unsafe or unexpected shutdown behavior, extended recovery	Medium

Reconnaissance and vulnerability validation only	Scanner reaches management interface but does not exploit	Increased likelihood of future targeting; possible credentials or banner leakage	High
--	---	--	------

MITRE ATT&CK Mapping

Technique	Name	Relevance
T1595	Active Scanning	Adversaries may scan for Vertiv UPS web interfaces, SNMP, BACnet/IP, or Modbus TCP exposure
T1190	Exploit Public-Facing Application	Applies when a UPS management web interface is exposed to an untrusted network
T1210	Exploitation of Remote Services	Applies to internal movement toward reachable UPS management services
T1068	Exploitation for Privilege Escalation	Embedded-device code execution may provide privileged execution on the card
T1105	Ingress Tool Transfer	Firmware/configuration upload functionality could be abused to transfer malicious content if controls fail
T1565.001	Data Manipulation: Stored Data Manipulation	Configuration tampering could alter UPS management behavior
T1491 / T1499	Defacement / Endpoint Denial of Service (contextual)	Not a perfect fit, but captures operational denial/disruption outcomes against managed equipment
T0882	Theft of Operational Information (ICS)	Access to UPS telemetry/configuration can expose operational dependencies
T0831	Manipulation of Control (ICS)	Unauthorized UPS-management changes may influence physical availability behavior
T0814	Denial of Service (ICS)	Compromised UPS card can contribute to loss of monitoring or service availability

6. Detection and Hunting

Detection should focus on exposure, abnormal access to UPS management interfaces, unexpected configuration/firmware operations, and reconnaissance against OT/facilities protocols. Because public reporting does not include a stable payload-level exploit indicator, defenders should avoid overfitting to single URI strings and instead correlate device identity, unauthenticated request patterns, management-change events, and network-origin anomalies.

Detection Objective	Telemetry Source	Signal	Priority
Identify exposed Vertiv UPS management interfaces	Asset inventory, firewall logs, vulnerability scanners, Zeek/NetFlow	HTTP/HTTPS to UPS card IPs from non-management networks	Critical
Detect suspicious web access attempts	Reverse proxy logs, firewall metadata, web logs where	Repeated 401/403/404, unusual paths containing	High

	available	login/reset/config/firmware keywords, requests from non-admin hosts	
Detect firmware/configuration changes	Device audit logs, backup/config management, syslog/SIEM	Firmware update events or config uploads outside approved maintenance windows	Critical
Detect scanning against UPS protocols	NetFlow, Zeek, firewall logs	TCP/80, 443, 23, 502, 47808, UDP/161 sweeps toward UPS/facilities subnets	High
Detect post-compromise staging	EDR/NDR, egress firewall	UPS card initiating unusual outbound traffic to internet or unapproved internal hosts	Medium-High

6.1 Microsoft Defender / Sentinel KQL Hunts

Hunt for non-management hosts connecting to known UPS management assets. Replace the watchlist name and IP ranges with local asset inventory values.

```
let Lookback = 14d;
let UpsAssets = (_GetWatchlist('OT_UPS_Management_Assets') | project UPS_IP = tostring(SearchKey), Site=tostring(Site), Product=tostring(Product));
let ApprovedMgmtHosts = (_GetWatchlist('Approved_OT_Admin_Hosts') | project AdminIP = tostring(SearchKey));
DeviceNetworkEvents
| where Timestamp > ago(Lookback)
| where RemotePort in (80, 443, 23, 161, 502, 47808) or LocalPort in (80, 443, 23, 161, 502, 47808)
| extend PossibleUpsIP = iff(RemoteIP in (UpsAssets), RemoteIP, LocalIP)
| join kind=inner UpsAssets on $left.PossibleUpsIP == $right.UPS_IP
| where not(InitiatingProcessAccountName has_any ('svc_ot_monitor', 'svc_backup'))
| where not(LocalIP in (ApprovedMgmtHosts) or RemoteIP in (ApprovedMgmtHosts))
| project Timestamp, DeviceName, LocalIP, RemoteIP, RemotePort, LocalPort, Protocol, InitiatingProcessFileName, InitiatingProcessAccountName, Site, Product
| order by Timestamp desc
```

Hunt for suspicious URL patterns against UPS web-management assets using proxy, firewall, or Defender network URL telemetry when available.

```
let Lookback = 30d;
let UpsAssetIPs = (_GetWatchlist('OT_UPS_Management_Assets') | project UPS_IP=tostring(SearchKey));
let SuspiciousTerms = dynamic(['login', 'reset', 'admin', 'password', 'firmware', 'upload', 'config', 'upgrade', 'cgi', 'fcgi']);
DeviceNetworkEvents
| where Timestamp > ago(Lookback)
| where RemoteIP in (UpsAssetIPs)
| where RemotePort in (80, 443)
| extend UrlLower = tolower(tostring(RemoteUrl))
| where UrlLower has_any (SuspiciousTerms) or InitiatingProcessCommandLine has_any (SuspiciousTerms)
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Attempts=count(), Terms=make_set(UrlLower, 20) by DeviceName, LocalIP, RemoteIP, InitiatingProcessFileName, InitiatingProcessAccountName
| where Attempts >= 3 or array_length(Terms) >= 2
| order by Attempts desc, LastSeen desc
```

6.2 Splunk SPL Hunts

Hunt for non-approved sources touching UPS management ports.

```
index=network (dest_port IN (80,443,23,161,502,47808) OR src_port IN (80,443,23,161,502,47808))
| lookup ot_ups_assets ip AS dest OUTPUT product site criticality
| where isnotnull(product)
| lookup approved_ot_admin_hosts ip AS src OUTPUT owner AS approved_owner
| where isnull(approved_owner)
```



```
| stats count min(_time) as first_seen max(_time) as last_seen values(dest_port) as ports
values(action) as actions by src dest product site criticality
| convert ctime(first_seen) ctime(last_seen)
| sort - count
```

Hunt for suspicious web-management verbs and path fragments in proxy or web logs.

```
(index=proxy OR index=web OR index=firewall) (dest_port=80 OR dest_port=443)
| lookup ot_ups_assets ip AS dest OUTPUT product site
| where isnotnull(product)
| eval uri_l=lower(coalesce(uri_path, url, http_uri, request, ""))
| search uri_l="*login*" OR uri_l="*reset*" OR uri_l="*admin*" OR uri_l="*password*" OR
uri_l="*firmware*" OR uri_l="*upload*" OR uri_l="*config*" OR uri_l="*upgrade*" OR uri_l="*cgi*"
| stats count values(uri_l) as sample_uris values(http_method) as methods values(status) as statuses by
src dest product site user user_agent
| where count > 2 OR mvcount(sample_uris) > 1
| sort - count
```

6.3 Sigma Detection Candidate

```
title: Suspicious Access to Vertiv or UPS Management Web Interface
id: 9f27bb4e-8df0-4b72-9a82-vertiv-ups-web-access
status: experimental
description: Detects suspicious web requests to known UPS management assets using path fragments
associated with authentication, configuration, firmware, or administrative operations. Requires an
asset lookup for UPS management device IPs.
author: Lost Boys Cyber
date: 2026-06-16
references:
  - https://claroty.com/team82/research/attacking-ups-network-cards-to-take-down-data-centers
  - https://www.cisa.gov/news-events/ics-advisories/icsa-25-140-10
logsource:
  category: proxy
  product: network
  service: web
custom:
  required_lookup: ot_ups_assets
  target_products:
    - Vertiv Liebert RDU101
    - Vertiv Liebert IS-UNITY
    - Vertiv Liebert IS-UNITY-DP
detection:
  selection_target:
    dst_ip|lookup: ot_ups_assets
  selection_terms:
    url|contains:
      - login
      - reset
      - admin
      - password
      - firmware
      - upload
      - config
      - upgrade
      - cgi
      - fcgi
  filter_approved_sources:
    src_ip|lookup: approved_ot_admin_hosts
  condition: selection_target and selection_terms and not filter_approved_sources
fields:
  - src_ip
  - dst_ip
  - url
  - http_method
  - status
  - user_agent
falsepositives:
```

- Approved maintenance from OT administrator jump hosts
- Vulnerability scanner activity during authorized assessment windows

level: high

6.4 Network and Asset-Inventory Queries

Use this Nmap approach only from approved internal scanning infrastructure and within a maintenance/assessment window.

```
# Replace targets.txt with authorized UPS/facilities subnets or known Vertiv management-card IPs.
nmap -sS -sV -O -Pn -p 80,443,23,161,502,47808 --open -iL targets.txt -oA vertiv-ups-management-exposure
```

Suggested Zeek/NetFlow triage fields:

Field	Use
`id.orig_h`	Identify non-management sources reaching UPS assets
`id.resp_h`	Confirm target is in UPS/facilities asset list
`id.resp_p`	Identify web, Telnet, SNMP, Modbus TCP, or BACnet/IP activity
`user_agent` / HTTP method	Flag scripts, scanners, or unusual tooling
`uri`	Review suspicious admin/config/firmware paths
Byte counts / duration	Identify upload-like behavior or repeated probing

7. Recommendations

Priority	Recommendation	Owner	Success Criteria
1	Upgrade Vertiv Liebert RDU101 to `1.9.1.2_0000001` or later and IS-UNITY to `8.4.3.1_00160` or later	Facilities / Data Center Operations	Firmware inventory confirms no vulnerable versions remain in production
1	Remove internet exposure and block direct access from general IT networks	Network Engineering	Firewall rules permit only approved admin jump hosts and monitoring collectors
1	Place UPS management cards in a dedicated management VLAN with ACLs and logging	Network Engineering / OT Security	Segmentation test confirms only approved paths reach ports 80/443/23/161/502/47808
2	Disable unused services such as Telnet, unauthenticated SNMP, Modbus TCP, or BACnet/IP where operationally unnecessary	Facilities / OT Engineering	Service baseline matches documented operational requirement
2	Enforce jump-host access with MFA, session logging, and named administrator accounts	IAM / Security Operations	UPS admin access is attributable to user identities and maintenance tickets
2	Review configuration and firmware-change history for the prior 30-90 days	Security Operations / Facilities	No unexplained firmware/config changes or suspicious source IPs remain unresolved
3	Add UPS management cards to	Vulnerability Management	Assets include product,

	CMDB/vulnerability management scope		firmware, owner, site, network segment, and maintenance window
3	Build tabletop scenario for UPS-management compromise during a power or cooling incident	Incident Response / Business Continuity	IR runbook includes facilities escalation and safe-shutdown decision authority

Additional hardening guidance:

- Treat UPS communication cards as OT/critical-infrastructure assets even when they are deployed in ordinary data centers.
- Prefer out-of-band management networks that are not routable from user workstations or server production VLANs.
- Restrict SNMP to SNMPv3 where supported; rotate community strings if SNMPv1/v2c is still required temporarily.
- Preserve device logs before firmware upgrades when suspicious activity is suspected.
- Validate that backup configuration files are protected; compromised backups can become a mechanism to reintroduce malicious or unsafe settings.
- Coordinate patching with facilities teams because firmware upgrades may affect monitoring integrations and safe-shutdown automation.

Indicators of Compromise

No source-validated malicious atomic indicators were disclosed for this work item. Lost Boys Cyber therefore treats this section as an IOC disposition record so downstream publication, OpenCTI hygiene, and detection-engineering workflows do not create placeholder blocklist entries.

Indicator Type	Value	Disposition
Affected product / vulnerability exposure	Vertiv UPS management-card vulnerability exposure; no malicious atomic IOCs disclosed	Track affected assets, firmware, and exploit-attempt telemetry rather than static IOCs.
Workflow context	threat-intel / threat-intel-intake	Use the report's detection and hunting logic for monitoring; do not promote non-malicious metadata into IOC-only controls.

8. References

- [1] Claroty Team82, “Attacking UPS Network Cards to Take Down Data Centers,” 2026-06-09: <https://claroty.com/team82/research/attacking-ups-network-cards-to-take-down-data-centers>
- [2] Industrial Cyber, “Claroty finds authentication bypass, RCE flaws in Vertiv UPS management cards that could disrupt data center operations,” 2026-06-11: <https://industrialcyber.co/control-device-security/claroty-finds-authentication-bypass-rce-flaws-in-vertiv-ups-management-cards-that-could-disrupt-data-center-operations/>
- [3] CISA ICS Advisory ICSA-25-140-10, “Vertiv Liebert RDU101 and UNITY”: <https://www.cisa.gov/news-events/ics-advisories/icsa-25-140-10>
- [4] Claroty disclosure dashboard entry for CVE-2025-41426: <https://www.claroty.com/team82/disclosure-dashboard/cve-2025-41426>
- [5] Vertiv support / software download page for Liebert Intellislot communications interface cards: <https://www.vertiv.com/de-emea/support/software-download/monitoring/liebert-intellislot-communications-interface-cards/>